Erkennung ungenutzter Bibliotheken in Deployments zur risikobasierten Priorisierung von Sicherheitsbefunden

Projektarbeit 1 (T4_1000)

Im Rahmen der Prüfung:

Bachelor of Science (B. Sc.)

des Studienganges Informatik

an der
Dualen Hochschule Baden-Württemberg Karlsruhe

von

Abgabedatum	05.01.2026
Bearbeitungszeitraum	20.10.2025 - 05.01.2026
Matrikelnummer, Kurs	, TIN
Ausbildungsfirma	SAP SE Dietmar-Hopp-Allee 16 69190 Walldorf, Deutschland
Betreuer der Ausbildungsfirma	
Gutachter der Dualen Hochschule	—

Eidesstattliche Erklärung

Ich versichere hiermit, dass ich meine Projektarbeit 1 (T4_1000) mit dem Thema:

> *Erkennung ungenutzter Bibliotheken in Deployments zur risikobasierten Priorisierung von Sicherheitsbefunden*

gemäß § 5 der „Studien- und Prüfungsordnung DHBW Technik“ vom 29. September 2017 selbstständig verfasst und keine anderen als die angegebenen Quellen und Hilfsmittel benutzt habe. Die Arbeit wurde bisher keiner anderen Prüfungsbehörde vorgelegt und auch nicht veröffentlicht.

Ich versichere zudem, dass die eingereichte elektronische Fassung mit der gedruckten Fassung übereinstimmt.

K, 23. Februar 2026

gez.: ,

Sperrvermerk

Die nachfolgende Arbeit enthält vertrauliche Daten der:

SAP SE
Dietmar-Hopp-Allee 16
69190 Walldorf
Deutschland

Der Inhalt dieser Arbeit darf weder als Ganzes noch in Auszügen Personen außerhalb des Prüfungsprozesses und des Evaluationsverfahrens zugänglich gemacht werden, sofern keine anderslautende Genehmigung vom Dualen Partner vorliegt.

Erklärung zur Nutzung Künstlicher Intelligenz

Für die folgende Arbeit wurde die Unterstützung Künstlicher Intelligenz genutzt.
Gemini 2.5 Flash und Gemini 2.5 Pro wurden genutzt, um bei der Literatur Recherche und Fachterminologie Suche zu unterstützen und Rechtschreibung, Grammatik und Ausdruck zu verbessern.
Obwohl diese Hilfsmittel meine Fähigkeiten erweitert und zu meinen Erkenntnissen beigetragen haben, ist es wichtig darauf hinzuweisen das sie inhärente Einschränkungen aufweisen. Ich habe mich bemüht jegliche Unterstützung Künstlicher Intelligenz transparent und verantwortungsvoll zu nutzen.

Diese Erklärung wurde von mir übersetzt, jedoch automatisch von AI Usage Cards generiert. https://ai-cards.org

Abstract

- English -

Abstract1

Abstract

- Deutsch -

Abstract2

Inhaltsverzeichnis

Tabellenverzeichnis ..... **IX**

1 Einleitung **1**
1.1 Motivation 1
1.2 Zielsetzung der Arbeit 2

2 Methodik **3**

3 Grundlagen **4**
3.1 Dependency Management 4
3.2 Software Bill of Materials (SBOM) 5
3.3 Bloated Dependencies 5
3.3.1 Definition und Abgrenzung 5
3.3.2 Kategorisierung 6
3.3.3 Entstehungsmechanismen 6
3.3.4 Empirische Evidenz 7
3.3.5 Konsequenzen 7
3.4 Vulnerability-Datenbanken 8
3.4.1 CVE und die National Vulnerability Database 8
3.4.2 Rolle in der Software Composition Analysis 9
3.4.3 Limitierungen für das Vulnerability-Management 9
3.4.4 CVE und die National Vulnerability Database 10
3.4.5 Rolle in der Software Composition Analysis 10
3.4.6 Limitierungen für das Vulnerability-Management 11
3.4.7 CVE und die National Vulnerability Database 12
3.4.8 Rolle in der Software Composition Analysis 12
3.4.9 Limitierungen für das Vulnerability-Management 13

4 Der aktuelle Forschungsstand **14**
4.1 Überblick und Einordnung (statisch vs. dynamisch; Evidence-Level) 14
4.2 Dynamische Ansätze (Tracing, Coverage, Runtime-Instrumentierung) 14
4.3 Statische Ansätze (Reachability, Call-Graphs, modulare Analysen) 14
4.4 Vergleich der Ansätze anhand Kriterien (Genauigkeit, Aufwand, K8s-Fit) 14
4.5 Ableitungen für den PoC in TypeScript/Node/Kubernetes 14

5 Methodenauswahl und PoC-Designentscheidung **15**
5.1 Bewertungsmatrix und Entscheidungsprozess 15
5.2 Gewählte Methode: L2-Reachability via Call-Graph 15
5.3 Zielartefakte und Schnittstellen (UsageFactor/Risk-Scoring) 15

6 Konzept des Proof of Concept **16**
6.1 Gesamtpipeline und Architektur 16
6.2 L0: Präsenzermittlung (Dependency-Tree/SBOM) 16
6.3 L1: Loaded-Heuristiken 16
6.4 L2: Reachability-Analyse (Entry Points, Graph, Mapping) 16
6.5 Ergebnisformat und Reporting 16

7 Implementierung **17**
7.1 Tooling-Stack und Projektstruktur 17
7.2 Dependency- und Code-Parsing (TS/AST) 17
7.3 Call-Graph-Konstruktion und Datenstrukturen 17
7.4 Mapping: Vulnerability/Package -> relevante Code-Elemente 17
7.5 Beispiel-Durchlauf (Demo-Projekt) 17
8 Evaluation **18**
8.1 Setup und Testkorpus 18
8.2 Metriken (Laufzeit, Abdeckung, FP/FN-Stichprobe) 18
8.3 Ergebnisse 18
8.4 Vergleich zur Baseline (z. B. npm audit) 18
8.5 Interpretation 18
9 Fazit und Ausblick **19**
9.1 Fazit (Rückbezug auf Forschungsfragen) 19
9.2 Ausblick (z. B. L2, bessere CVE->Symbol-Zuordnung, CI/CD-Integration) . 19
Literaturverzeichnis ..... **a**

Abkürzungsverzeichnis

***TS* – TypeScript** 6

Tabellenverzeichnis

Tabelle 1 Anteil bloated Dependencies nach Typ in Maven und npm-Ökosystem. Quellen: [1], [2]. 7

1 Einleitung

1.1 Motivation

Dependency Scanner wie npm audit und OWASP Dependency-Check sind aus der modernen Softwareentwicklung nicht mehr wegzudenken [3]. Diese Tools basieren primär auf Software Bill of Materials (SBOM) und operieren ausschließlich auf Package-Ebene [4]. Aktuelle Forschung zeigt jedoch fundamentale Limitierungen dieser Ansätze, die zu erheblichen praktischen Problemen führen.

Die Unfähigkeit zu erkennen, ob Code tatsächlich zur Laufzeit ausgeführt wird, führt zu zwei kritischen Problemen. Erstens akkumulieren Projekte obsolete Dependencies, die erhebliche Wartungskosten verursachen [5]. Empirische Analysen zeigen, dass 75,1% aller Maven-Dependencies als „bloated“ klassifiziert werden können, wobei 57% der transitiven Dependencies vollständig ungenutzt sind [6]. Im JavaScript-Ökosystem ist die Situation vergleichbar: 50,7% der Dependencies in CommonJS-Packages sind bloated [2].

Diese obsoleten Dependencies entstehen durch verschiedene Mechanismen. Transitive Abhängigkeiten werden automatisch in die Dependency-Hierarchie eingefügt, ohne dass Entwickler sich deren Präsenz bewusst sind [5]. Darüber hinaus werden Dependencies während der Entwicklung hinzugefügt und bei Code-Refactorings nicht entfernt [2]. Das Entfernen ist jedoch oft schwierig, weil Entwickler nicht mit ausreichender Sicherheit beurteilen können, ob eine Dependency wirklich entbehrlich ist [5]. Die resultierenden Kosten manifestieren sich in erhöhten Binary-Größen, verlängerten Build-Zeiten, erhöhtem Speicherverbrauch und gesteigertem Sicherheitsrisiko durch eine vergrößerte Angriffsfläche [6], [7]. In containerisierten Deployments wird die Problematik besonders sichtbar, da Images teils eine große Menge veralteter oder verwundbarer JavaScript-Pakete enthalten [8].

Zweitens führt die Fokussierung auf Package-Level-Analysen zu einer hohen Rate an False-Positive-Warnungen. Die zentrale Herausforderung liegt in der fehlenden Granularität: SBOM-basierte Tools können nicht zwischen deployed und nicht-deployed Code differenzieren [9], noch können sie feststellen, ob vulnerable Funktionen tatsächlich vom Anwendungscode aufgerufen werden.

1.2 Zielsetzung der Arbeit

2 Methodik

3 Grundlagen

3.1 Dependency Management

Modern entwickelte JavaScript- und TypeScript-Anwendungen stützen sich in hohem Maße auf externe Bibliotheken. Um diese zu verwalten, verwenden Entwickler den Package Manager npm (Node Package Manager). Ein Package Manager übernimmt drei zentrale Aufgaben: Er liest Manifest-Dateien wie `package.json`, lädt die deklarierten Bibliotheken aus dem zentralen npm-Registry herunter und installiert sie lokal im Projekt [10]. Dabei löst er nicht nur die explizit angeforderten Dependencies auf, sondern rekursiv auch alle deren Abhängigkeiten.

Dependencies lassen sich in zwei Kategorien einteilen. Direkte Dependencies werden explizit im Projekt-Manifest deklariert, beispielsweise `express` in der `package.json`. Der Anwendungscode importiert und nutzt diese Bibliotheken direkt. Transitive Dependencies hingegen sind Abhängigkeiten dieser direkten Dependencies [1]. Wenn ein Node.js-Projekt `express@4.18.2` deklariert, installiert npm automatisch auch die 31 Dependencies von express, darunter `body-parser`, `cookie` und `debug`. Alle installierten Packages werden im `node_modules`-Verzeichnis abgelegt.

Dieser Mechanismus führt zum Phänomen der Dependency Amplification: Eine einzelne direkte Dependency zieht eine Kaskade weiterer Dependencies nach sich [11]. Ein Projekt mit 50 direkten Dependencies kann so auf mehrere hundert installierte Packages anwachsen [11].

Bei TypeScript-Projekten wird diese Amplification zusätzlich verstärkt: Für jede JavaScript-Bibliothek ohne eingebaute Typdefinitionen muss ein separates Type-Definition-Package aus dem `@types/*`-Namespace installiert werden. Nutzt ein Projekt beispielsweise `express`, muss zusätzlich `@types/express` installiert werden, um TypeScript-Typen zu erhalten. npm unterscheidet zwischen `dependencies` (zur Laufzeit benötigt) und `devDependencies` (nur für Build/Test). Type-Definition-Packages werden als `devDependencies` deklariert, da sie ausschließlich zur Compile-Zeit erforderlich sind.

Diese Dependency Amplification führt zu einem fundamentalen Problem: Bei hunderten automatisch installierten Packages verlieren Entwickler den Überblick, welche Dependencies tatsächlich vom Anwendungscode genutzt werden. Die in Abschnitt 1.1 beschriebenen Konsequenzen (akkumulierte bloated dependencies, erhöhte Sicherheits-

risiken und False-Positive-Warnungen in Vulnerability Scannern) sind direkte Folgen dieses Mechanismus.

3.2 Software Bill of Materials (SBOM)

Wie in der Motivation beschrieben, basieren Scanner wie npm audit oder OWASP Dependency-Check auf Software Bills of Materials (SBOMs). Ein SBOM ist eine maschinenlesbare Liste aller Softwarekomponenten eines Produkts [12]. Im Gegensatz zu Manifest-Dateien wie `package.json`, die nur direkte Dependencies auflisten, erfasst ein SBOM auch alle transitiven Dependencies mit exakten Versionen. Die NTIA spezifiziert Mindestinhalte [13], das verbreitetste Format ist SPDX (ISO/IEC 5962:2021) [14].

SBOMs werden typischerweise durch spezialisierte Tools wie CycloneDX, Syft oder das Microsoft SBOM Tool aus den Dependency-Informationen eines Projekts generiert. Jeder SBOM-Eintrag dokumentiert eine Softwarekomponente mit folgenden Informationen: Paketname (z.B. `express`), Version (`4.18.2`), eindeutiger Identifikator als Package-URL (`pkg:npm/express@4.18.2`), Lizenzinformation (`MIT`), Lieferant sowie die Liste der direkten Dependencies dieser Komponente. Für ein typisches Node.js-Projekt mit 50 direkten Dependencies kann ein SBOM mehrere hundert Einträge umfassen, da auch alle transitiven Dependencies erfasst werden müssen.

Die fundamentale Einschränkung von SBOMs liegt im Detailgrad der Dokumentation: Dependencies werden auf Package-Ebene dokumentiert. Eine Bibliothek wird als Ganzes erfasst, unabhängig davon, welche ihrer Funktionen tatsächlich genutzt werden. Bindet ein Projekt die Bibliothek `lodash` ein und nutzt nur die Funktion `_.debounce()`, erfasst das SBOM lediglich `lodash@4.17.21` als Dependency, ohne zu dokumentieren, welche der über 300 verfügbaren Funktionen von lodash im Code aufgerufen werden.

3.3 Bloated Dependencies

3.3.1 Definition und Abgrenzung

Als **bloated** werden Dependencies bezeichnet, die im Deployment einer Anwendung installiert sind, aber zur Laufzeit nie verwendet werden [1]. Bestehende Analyse-Tools fokussieren primär auf veraltete (*outdated*) und verwundbare (*vulnerable*) Dependencies. Eine Dependency kann jedoch veraltet sein, ohne ungenutzt zu sein, und eine

verwundbare Dependency muss nicht zwingend bloated sein. Diese Arbeit ergänzt die bestehenden Dimensionen um den Aspekt der genutzten Codebasis.

3.3.2 Kategorisierung

Bloated Dependencies lassen sich nach ihrer Herkunft in zwei für npm relevante Typen einteilen. **Direkte** bloated Dependencies sind explizit im Manifest deklariert, werden jedoch nie vom Anwendungscode aufgerufen. **Transitive** bloated Dependencies wurden automatisch als Abhängigkeiten anderer Packages installiert, ohne dass die Anwendung sie je verwendet [1]. Transitive bloated Dependencies sind in der Praxis dominierend, da der Dependency-Auflösungsmechanismus sie automatisch und ohne direktes Zutun der Entwickler in den Abhängigkeitsbaum einfügt (vgl. Abschnitt 3.1). Im Maven-Ökosystem existiert zusätzlich die Kategorie **geerbter** Dependencies aus Parent-POMs, die in *TypeScript (TS)* keine Entsprechung hat und daher in dieser Arbeit nicht weiter betrachtet wird.

3.3.3 Entstehungsmechanismen

Bloated Dependencies entstehen durch verschiedene Mechanismen. Bei **direkten** Dependencies tritt häufig evolutionäre Akkumulation auf: Wenn Features umgebaut oder entfernt werden, bleiben die zugehörigen Packages oft im Manifest erhalten [5]. Bei **transitiven** Dependencies ist der Mechanismus fundamentaler: Sie werden automatisch installiert, sobald eine direkte Dependency sie benötigt. Entfernt man später Code, der diese direkte Dependency nutzte, muss die Deklaration manuell aus dem Manifest entfernt werden. Geschieht dies nicht, bleiben alle transitiven Dependencies dieser Dependency installiert, selbst wenn keine davon mehr genutzt wird (vgl. Abschnitt 3.1).

Das nachträgliche Entfernen ist für Entwickler riskant. Statische Analysetools melden zahlreiche False Positives, weil sie dynamische Sprachfeatures wie `eval()`, `require()` mit variablen Parametern oder dynamische Imports nicht vollständig erfassen können. Empirisch zeigt sich, dass Ansätze, die Call-Graph-Analyse mit einer Klassifikation der Dependency-Beziehungen kombinieren, rund ein Drittel dieser False Positives eliminieren können [5]. Eine explorative Studie mit 23 Pull Requests deutet an, dass erhebliche Unsicherheiten besonders bei transitiven Dependencies bestehen: Während Entwickler 14 von 15 Vorschlägen zur Entfernung direkter bloated Dependencies akzeptierten, nahmen sie nur 4 von 8 Vorschläge zu transitiven Dependencies an [1].

3.3.4 Empirische Evidenz

Das Problem ist weit verbreitet. Im JavaScript-Ökosystem sind 50,6% aller Dependencies bloated [2]. Im Maven-Ökosystem fällt das Bild noch deutlicher aus: 75,1% aller Dependencies sind bloated, wie eine Analyse von 9.639 Artefakten zeigt [1]. Die Messgrößen unterscheiden sich dabei methodisch: Maven erfasst Dependency-Beziehungen als Kanten im Dependency-Graph (N = 723.444), npm hingegen einzelne Package-Installationen (N = 50.488). Die Prozentwerte sind daher nur bedingt direkt vergleichbar, zeigen aber in beiden Ökosystemen einen hohen Anteil ungenutzter Dependencies. Tabelle 1 zeigt die Verteilung nach Typ.

Typ	**Maven**	**CommonJS/npm**
Direkt (bloated)	2,7%	13,8%
Transitiv (bloated)	57,0%	51,3%
Gesamt bloated	**75,1%**	**50,6%**

Tabelle 1: Anteil bloated Dependencies nach Typ in Maven und npm-Ökosystem. Quellen: [1], [2].

Über beide Ökosysteme hinweg zeigt sich ein konsistentes Muster: Transitive Dependencies machen den Großteil des Bloats aus, während direkte Dependencies seltener betroffen sind. Im Maven-Ökosystem existiert zusätzlich die Kategorie geerbter Dependencies aus Parent-POMs (15,4% bloated), die in npm keine Entsprechung hat. Auf Projektebene ist die Verbreitung besonders hoch: 86,2% aller Maven-Artefakte und 98,9% aller untersuchten CommonJS-Packages enthalten mindestens eine bloated-transitive Dependency [1], [2].

Die Hebelwirkung des Entfernens lässt sich am Package `podcast-search` verdeutlichen [2]. Das Projekt hat zwei direkte Dependencies, von denen `npm` zur Laufzeit nie verwendet wird. Alle 679 transitiven Dependencies stammen ausschließlich von dieser einen ungenutzten Dependency. Das Entfernen einer einzigen Zeile in der `package.json` eliminiert so 680 von insgesamt 681 installierten Dependencies, ohne Funktionsverlust.

3.3.5 Konsequenzen

Dependency Bloat hat technische, wirtschaftliche und sicherheitskritische Folgen. Überflüssige Packages erhöhen die Binary-Größe, verlängern Installations- und Build-Zeiten und steigern den Speicherbedarf. In containerisierten Deployments, wo TypeScript-Anwendungen typischerweise betrieben werden, wird dies besonders sichtbar: Analysen

offizieller Docker-Images zeigen, dass alle untersuchten Images verwundbare npm-Packages enthalten, im Durchschnitt 16,6 Security-Vulnerabilities pro Container [8].

Dependency-Scanner erkennen diese Vulnerabilities unabhängig von der tatsächlichen Erreichbarkeit des betroffenen Codes. Sicherheitskritisch ist dabei vor allem die vergrößerte Angriffsfläche: Jede zusätzlich installierte Bibliothek kann bekannte Schwachstellen (CVEs) einbringen. SBOM-basierte Scanner erfassen eine Bibliothek als Ganzes, ohne zu berücksichtigen, welche ihrer Funktionen tatsächlich aufgerufen werden. Ponta et al. zeigen, dass erst eine code-zentrische, nutzungsbasierte Analyse feststellen kann, ob vulnerable Funktionen im konkreten Anwendungskontext tatsächlich erreichbar sind [4]. Eine bloated Dependency mit einer bekannten Schwachstelle löst daher eine Warnung aus, obwohl kein Codepfad die Schwachstelle je erreichen könnte. Die Reduktion von Dependency Bloat ist damit nicht nur eine Maintenance-Maßnahme, sondern eine Voraussetzung für präziseres Vulnerability-Management.

3.4 Vulnerability-Datenbanken

3.4.1 CVE und die National Vulnerability Database

Das Common Vulnerabilities and Exposures (CVE) Programm ist der zentrale Standard zur einheitlichen Benennung öffentlich bekannter Sicherheitslücken [15]. Jede Schwachstelle erhält einen eindeutigen Bezeichner in der Form CVE-JAHR-NUMMER, der eine ökosystemübergreifende Referenzierung ermöglicht. Die National Vulnerability Database (NVD) des amerikanischen National Institute of Standards and Technology (NIST) baut auf diesem Standard auf und reichert CVE-Einträge mit strukturierten Metadaten an [16].

Anwar et al. beschreiben die Struktur eines NVD-Eintrags systematisch: Jeder Eintrag enthält einen eindeutigen CVE-Bezeichner, das Veröffentlichungsdatum, eine Klassifikation des Schwachstellentyps nach der Common Weakness Enumeration (CWE), einen Schweregrad-Score nach dem Common Vulnerability Scoring System (CVSS) sowie eine Liste betroffener Produkte und Hersteller nach der Common Platform Enumeration (CPE) [17]. Diese standardisierten Felder ermöglichen es, eine Schwachstelle maschinell mit konkreten Softwareversionen zu verknüpfen. Shi et al. zeigen, dass die Beziehungen zwischen diesen drei Datenbanken (CVE, CWE, CPE) komplex und teilweise

unvollständig sind, und schlagen Knowledge-Graph-Verfahren zur automatisierten Vervollständigung vor [18].

3.4.2 Rolle in der Software Composition Analysis

Dependency-Scanner wie npm audit oder OWASP Dependency-Check nutzen NVD als primäre Datenquelle [3], [19]. Der Ablauf folgt einem einheitlichen Schema: Der Scanner erstellt zunächst eine Liste aller installierten Packages mit ihren Versionen, gleicht diese gegen die CPE-Einträge der NVD ab und meldet Treffer als potenzielle Schwachstellen. Ponta et al. bezeichnen diesen Prozess als metadatenbasierte Analyse, da ausschließlich Paketname und Versionsnummer zur Zuordnung herangezogen werden, ohne zu prüfen, ob der betroffene Code tatsächlich im Anwendungskontext aufgerufen wird [3].

Ein zentrales Problem dieser Zuordnung liegt in der Granularität der CPE-Angaben. NVD-Einträge benennen betroffene Softwareprodukte auf Package-Ebene, ohne zu spezifizieren, welche Funktionen einer Bibliothek die Schwachstelle enthalten. Haryono et al. zeigen, dass bereits die vorgelagerte Aufgabe, betroffene Libraries überhaupt aus einem NVD-Eintrag zu identifizieren, nicht-trivial ist: NVD-Berichte nennen betroffene Packages häufig nicht explizit, sodass die Zuordnung auf Machine-Learning-Verfahren angewiesen ist [20]. Diese Unschärfe pflanzt sich in alle darauf aufbauenden Scanner fort.

3.4.3 Limitierungen für das Vulnerability-Management

Die NVD weist mehrere systematische Schwächen auf, die das Vulnerability-Management in der Praxis erschweren. Wunder et al. zeigen in einer empirischen Nutzerstudie mit sieben Interviews und 71 Umfrageteilnehmern, dass Anwender vor allem drei Probleme benennen: fehlende oder falsche Einträge, unvollständige Beschreibungen sowie unverständliche CVSS-Bewertungen [21]. Viele dieser Probleme lassen sich auf vorgelagerte Schwächen im CVE-Programm selbst zurückführen, da die NVD auf den Eingaben externer CVE Numbering Authorities aufbaut.

Die gravierendste Einschränkung für die Praxis liegt jedoch im Detailgrad der Schwachstellenzuordnung. Da NVD-basierte Scanner ausschließlich auf Package-Ebene operieren, können sie nicht feststellen, ob der vulnerable Code im konkreten Deployment tatsächlich erreichbar ist. Ponta et al. quantifizieren dieses Problem empirisch: Ein Vergleich von OWASP Dependency-Check mit dem code-zentrischen Ansatz Eclipse Steady an 300 Unternehmensanwendungen mit insgesamt 78.165 Abhängigkeiten zeigt, dass 88,8% der OWASP-DC-Befunde für code-basierte Schwachstellen, bei denen

nur OWASP DC einen Treffer meldete, False Positives sind [3]. Pashchenko et al. ergänzen, dass eine präzise Zählung vulnerabler Dependencies zusätzlich zwischen Laufzeit- und Entwicklungs-Dependencies unterscheiden muss: In npm werden letztere im `devDependencies`-Abschnitt der Konfigurationsdatei deklariert und im Deployment nicht installiert, sodass sie keine Angriffsfläche bieten können [9].

Diese Befunde sind direkt mit dem in Abschnitt 3.3 beschriebenen Bloat-Problem verbunden: Enthält ein Deployment eine bloated Dependency mit einem bekannten CVE, erzeugt ein NVD-basierter Scanner eine Warnung, obwohl der vulnerable Code strukturell unerreichbar ist. Das Vulnerability-Management lässt sich damit erst dann präzisieren, wenn die tatsächliche Nutzung einer Dependency zur Laufzeit bekannt ist.

3.4.4 CVE und die National Vulnerability Database

Das Common Vulnerabilities and Exposures (CVE) Programm ist der zentrale Standard zur einheitlichen Benennung öffentlich bekannter Sicherheitslücken [15]. Jede Schwachstelle erhält einen eindeutigen Bezeichner in der Form CVE-JAHR-NUMMER, der eine ökosystemübergreifende Referenzierung ermöglicht. Die National Vulnerability Database (NVD) des amerikanischen National Institute of Standards and Technology (NIST) baut auf diesem Standard auf und reichert CVE-Einträge mit strukturierten Metadaten an [16].

Anwar et al. beschreiben die Struktur eines NVD-Eintrags systematisch: Jeder Eintrag enthält einen eindeutigen CVE-Bezeichner, das Veröffentlichungsdatum, eine Klassifikation des Schwachstellentyps nach der Common Weakness Enumeration (CWE), einen Schweregrad-Score nach dem Common Vulnerability Scoring System (CVSS) sowie eine Liste betroffener Produkte und Hersteller nach der Common Platform Enumeration (CPE) [17]. Diese standardisierten Felder ermöglichen es, eine Schwachstelle maschinell mit konkreten Softwareversionen zu verknüpfen. Shi et al. zeigen, dass die Beziehungen zwischen diesen drei Datenbanken (CVE, CWE, CPE) komplex und teilweise unvollständig sind, und schlagen Knowledge-Graph-Verfahren zur automatisierten Vervollständigung vor [18].

3.4.5 Rolle in der Software Composition Analysis

Dependency-Scanner wie npm audit oder OWASP Dependency-Check nutzen NVD als primäre Datenquelle [3], [19]. Der Ablauf folgt einem einheitlichen Schema: Der Scanner erstellt zunächst eine Liste aller installierten Packages mit ihren Versionen, gleicht diese

gegen die CPE-Einträge der NVD ab und meldet Treffer als potenzielle Schwachstellen. Ponta et al. bezeichnen diesen Prozess als metadatenbasierte Analyse, da ausschließlich Paketname und Versionsnummer zur Zuordnung herangezogen werden, ohne zu prüfen, ob der betroffene Code tatsächlich im Anwendungskontext aufgerufen wird [3].

Ein zentrales Problem dieser Zuordnung liegt in der Granularität der CPE-Angaben. NVD-Einträge benennen betroffene Softwareprodukte auf Package-Ebene, ohne zu spezifizieren, welche Funktionen einer Bibliothek die Schwachstelle enthalten. Haryono et al. zeigen, dass bereits die vorgelagerte Aufgabe, betroffene Libraries überhaupt aus einem NVD-Eintrag zu identifizieren, nicht-trivial ist: NVD-Berichte nennen betroffene Packages häufig nicht explizit, sodass die Zuordnung auf Machine-Learning-Verfahren angewiesen ist [20]. Diese Unschärfe pflanzt sich in alle darauf aufbauenden Scanner fort.

3.4.6 Limitierungen für das Vulnerability-Management

Die NVD weist mehrere systematische Schwächen auf, die das Vulnerability-Management in der Praxis erschweren. Wunder et al. zeigen in einer empirischen Nutzerstudie mit sieben Interviews und 71 Umfrageteilnehmern, dass Anwender vor allem drei Probleme benennen: fehlende oder falsche Einträge, unvollständige Beschreibungen sowie unverständliche CVSS-Bewertungen [21]. Viele dieser Probleme lassen sich auf vorgelagerte Schwächen im CVE-Programm selbst zurückführen, da die NVD auf den Eingaben externer CVE Numbering Authorities aufbaut.

Die gravierendste Einschränkung für die Praxis liegt jedoch im Detailgrad der Schwachstellenzuordnung. Da NVD-basierte Scanner ausschließlich auf Package-Ebene operieren, können sie nicht feststellen, ob der vulnerable Code im konkreten Deployment tatsächlich erreichbar ist. Ponta et al. quantifizieren dieses Problem empirisch: Ein Vergleich von OWASP Dependency-Check mit dem code-zentrischen Ansatz Eclipse Steady an 300 Unternehmensanwendungen mit insgesamt 78.165 Abhängigkeiten zeigt, dass 88,8% der OWASP-DC-Befunde für code-basierte Schwachstellen, bei denen nur OWASP DC einen Treffer meldete, False Positives sind [3]. Pashchenko et al. ergänzen, dass eine präzise Zählung vulnerabler Dependencies zusätzlich zwischen Laufzeit- und Entwicklungs-Dependencies unterscheiden muss: In npm werden letztere im `devDependencies`-Abschnitt der Konfigurationsdatei deklariert und im Deployment nicht installiert, sodass sie keine Angriffsfläche bieten können [9].

Diese Befunde sind direkt mit dem in Abschnitt 3.3 beschriebenen Bloat-Problem verbunden: Enthält ein Deployment eine bloated Dependency mit einem bekannten

CVE, erzeugt ein NVD-basierter Scanner eine Warnung, obwohl der vulnerable Code strukturell unerreichbar ist. Das Vulnerability-Management lässt sich damit erst dann präzisieren, wenn die tatsächliche Nutzung einer Dependency zur Laufzeit bekannt ist.

3.4.7 CVE und die National Vulnerability Database

Das Common Vulnerabilities and Exposures (CVE) Programm ist der zentrale Standard zur einheitlichen Benennung öffentlich bekannter Sicherheitslücken [15]. Jede Schwachstelle erhält einen eindeutigen Bezeichner in der Form CVE-JAHR-NUMMER, der eine ökosystemübergreifende Referenzierung ermöglicht. Die National Vulnerability Database (NVD) des amerikanischen National Institute of Standards and Technology (NIST) baut auf diesem Standard auf und reichert CVE-Einträge mit strukturierten Metadaten an [16].

Anwar et al. beschreiben die Struktur eines NVD-Eintrags systematisch: Jeder Eintrag enthält einen eindeutigen CVE-Bezeichner, das Veröffentlichungsdatum, eine Klassifikation des Schwachstellentyps nach der Common Weakness Enumeration (CWE), einen Schweregrad-Score nach dem Common Vulnerability Scoring System (CVSS) sowie eine Liste betroffener Produkte und Hersteller nach der Common Platform Enumeration (CPE) [17]. Diese standardisierten Felder ermöglichen es, eine Schwachstelle maschinell mit konkreten Softwareversionen zu verknüpfen. Shi et al. zeigen, dass die Beziehungen zwischen diesen drei Datenbanken (CVE, CWE, CPE) komplex und teilweise unvollständig sind, und schlagen Knowledge-Graph-Verfahren zur automatisierten Vervollständigung vor [18].

3.4.8 Rolle in der Software Composition Analysis

Dependency-Scanner wie npm audit oder OWASP Dependency-Check nutzen NVD als primäre Datenquelle [3], [19]. Der Ablauf folgt einem einheitlichen Schema: Der Scanner erstellt zunächst eine Liste aller installierten Packages mit ihren Versionen, gleicht diese gegen die CPE-Einträge der NVD ab und meldet Treffer als potenzielle Schwachstellen. Ponta et al. bezeichnen diesen Prozess als metadatenbasierte Analyse, da ausschließlich Paketname und Versionsnummer zur Zuordnung herangezogen werden, ohne zu prüfen, ob der betroffene Code tatsächlich im Anwendungskontext aufgerufen wird [3].

Ein zentrales Problem dieser Zuordnung liegt in der Granularität der CPE-Angaben. NVD-Einträge benennen betroffene Softwareprodukte auf Package-Ebene, ohne zu spezifizieren, welche Funktionen einer Bibliothek die Schwachstelle enthalten. Haryono

et al. zeigen, dass bereits die vorgelagerte Aufgabe, betroffene Libraries überhaupt aus einem NVD-Eintrag zu identifizieren, nicht-trivial ist: NVD-Berichte nennen betroffene Packages häufig nicht explizit, sodass die Zuordnung auf Machine-Learning-Verfahren angewiesen ist [20]. Diese Unschärfe pflanzt sich in alle darauf aufbauenden Scanner fort.

3.4.9 Limitierungen für das Vulnerability-Management

Die NVD weist mehrere systematische Schwächen auf, die das Vulnerability-Management in der Praxis erschweren. Wunder et al. zeigen in einer empirischen Nutzerstudie mit sieben Interviews und 71 Umfrageteilnehmern, dass Anwender vor allem drei Probleme benennen: fehlende oder falsche Einträge, unvollständige Beschreibungen sowie unverständliche CVSS-Bewertungen [21]. Viele dieser Probleme lassen sich auf vorgelagerte Schwächen im CVE-Programm selbst zurückführen, da die NVD auf den Eingaben externer CVE Numbering Authorities aufbaut.

Die gravierendste Einschränkung für die Praxis liegt jedoch im Detailgrad der Schwachstellenzuordnung. Da NVD-basierte Scanner ausschließlich auf Package-Ebene operieren, können sie nicht feststellen, ob der vulnerable Code im konkreten Deployment tatsächlich erreichbar ist. Ponta et al. quantifizieren dieses Problem empirisch: Ein Vergleich von OWASP Dependency-Check mit dem code-zentrischen Ansatz Eclipse Steady an 300 Unternehmensanwendungen mit insgesamt 78.165 Abhängigkeiten zeigt, dass 88,8% der OWASP-DC-Befunde für code-basierte Schwachstellen, bei denen nur OWASP DC einen Treffer meldete, False Positives sind [3]. Pashchenko et al. ergänzen, dass eine präzise Zählung vulnerabler Dependencies zusätzlich zwischen Laufzeit- und Entwicklungs-Dependencies unterscheiden muss: In npm werden letztere im `devDependencies`-Abschnitt der Konfigurationsdatei deklariert und im Deployment nicht installiert, sodass sie keine Angriffsfläche bieten können [9].

Diese Befunde sind direkt mit dem in Abschnitt 3.3 beschriebenen Bloat-Problem verbunden: Enthält ein Deployment eine bloated Dependency mit einem bekannten CVE, erzeugt ein NVD-basierter Scanner eine Warnung, obwohl der vulnerable Code strukturell unerreichbar ist. Das Vulnerability-Management lässt sich damit erst dann präzisieren, wenn die tatsächliche Nutzung einer Dependency zur Laufzeit bekannt ist.

4 Der aktuelle Forschungsstand

4.1 Überblick und Einordnung (statisch vs. dynamisch; Evidence-Level)

4.2 Dynamische Ansätze (Tracing, Coverage, Runtime-Instrumentierung)

4.3 Statische Ansätze (Reachability, Call-Graphs, modulare Analysen)

4.4 Vergleich der Ansätze anhand Kriterien (Genauigkeit, Aufwand, K8s-Fit)

4.5 Ableitungen für den PoC in TypeScript/Node/Kubernetes

5 Methodenauswahl und PoC-Designentscheidung

5.1 Bewertungsmatrix und Entscheidungsprozess

5.2 Gewählte Methode: L2-Reachability via Call-Graph

5.3 Zielartefakte und Schnittstellen (UsageFactor/Risk-Scoring)

6 Konzept des Proof of Concept

6.1 Gesamtpipeline und Architektur

6.2 L0: Präsenzermittlung (Dependency-Tree/SBOM)

6.3 L1: Loaded-Heuristiken

6.4 L2: Reachability-Analyse (Entry Points, Graph, Mapping)

6.5 Ergebnisformat und Reporting

7 Implementierung

7.1 Tooling-Stack und Projektstruktur

7.2 Dependency- und Code-Parsing (TS/AST)

7.3 Call-Graph-Konstruktion und Datenstrukturen

7.4 Mapping: Vulnerability/Package -> relevante Code-Elemente

7.5 Beispiel-Durchlauf (Demo-Projekt)

8 Evaluation

8.1 Setup und Testkorpus

8.2 Metriken (Laufzeit, Abdeckung, FP/FN-Stichprobe)

8.3 Ergebnisse

8.4 Vergleich zur Baseline (z. B. npm audit)

8.5 Interpretation

9 Fazit und Ausblick

9.1 Fazit (Rückbezug auf Forschungsfragen)

9.2 Ausblick (z. B. L2, bessere CVE->Symbol-Zuordnung, CI/CD-Integration)

Literaturverzeichnis

[1] C. Soto-Valero, M. Monperrus, und B. Baudry, „A comprehensive study of bloated dependencies in the Maven ecosystem“, *Empirical Software Engineering*, Bd. 26, Nr. 4, S. 1–36, 2021, doi: 10.1007/s10664-020-09914-8.

[2] Y. Liu, D. Tiwari, C. Bogdan, und B. Baudry, „Detecting and removing bloated dependencies in CommonJS packages“, *Journal of Systems and Software*, Bd. 230, S. 112509, Dez. 2025, doi: 10.1016/j.jss.2025.112509.

[3] S. E. Ponta, H. Plate, und A. Sabetta, „Detection, assessment and mitigation of vulnerabilities in open source dependencies“, *Empirical Software Engineering*, Bd. 25, Nr. 5, S. 3175–3215, 2020, doi: 10.1007/s10664-020-09830-x.

[4] S. E. Ponta, H. Plate, und A. Sabetta, „Beyond Metadata: Code-Centric and Usage-Based Analysis of Known Vulnerabilities in Open-Source Software“, in *2018 IEEE International Conference on Software Maintenance and Evolution (ICSME)*, 2018, S. 449–460. doi: 10.1109/ICSME.2018.00054.

[5] C.-C. Chuang, L. Cruz, R. van Dalen, V. Mikovski, und A. van Deursen, „ Removing dependencies from large software projects: are you really sure? “, in *2022 IEEE 22nd International Working Conference on Source Code Analysis and Manipulation (SCAM)*, Los Alamitos, CA, USA: IEEE Computer Society, Okt. 2022, S. 105–115. doi: 10.1109/SCAM55253.2022.00017.

[6] C. Soto-Valero und others, „A comprehensive study of bloated dependencies in the Maven ecosystem“, *Empirical Software Engineering*, 2021, doi: 10.1007/s10664-020-09914-8.

[7] C. Soto-Valero, T. Durieux, N. Harrand, und B. Baudry, „Coverage-based debloating for java bytecode“, *ACM Transactions on Software Engineering and Methodology*, Bd. 32, Nr. 2, S. 1–34, 2023.

[8] A. Zerouali, V. Cosentino, T. Mens, G. Robles, und J. M. Gonzalez-Barahona, „On the Impact of Outdated and Vulnerable Javascript Packages in Docker Images“, in *2019 IEEE 26th International Conference on Software Analysis, Evolution and Reengineering (SANER)*, 2019, S. 619–623. doi: 10.1109/SANER.2019.8667984.

[9] I. Pashchenko, H. Plate, S. E. Ponta, A. Sabetta, und F. Massacci, „Vuln4Real: A Methodology for Counting Actually Vulnerable Dependencies“, *IEEE Transac-*

tions on Software Engineering, Bd. 48, Nr. 5, S. 1592–1609, 2022, doi: 10.1109/TSE.2020.3025443.

[10] A. Decan, T. Mens, und M. Claes, „An empirical comparison of dependency network evolution in seven software packaging ecosystems“, *Empirical Software Engineering*, Bd. 24, Nr. 1, S. 381–416, 2019, doi: 10.1007/s10664-017-9589-y.

[11] R. Kikas, R. Söre, M. Dumas, und D. Pfahl, „Demystifying the Vulnerability Propagation and Its Evolution via Dependency Trees in the NPM Ecosystem“, in *Proceedings of the 19th International Conference on Mining Software Repositories (MSR)*, ACM, 2022, S. 220–231. doi: 10.1145/3510003.3510142.

[12] National Telecommunications and Information Administration, „Software Bill of Materials (SBOM)“. 2021.

[13] National Telecommunications and Information Administration, „The Minimum Elements for a Software Bill of Materials (SBOM)“. [Online]. Verfügbar unter: https://www.ntia.gov/files/ntia/publications/sbom_minimum_elements_report.pdf

[14] International Organization for Standardization und International Electrotechnical Commission, „Information technology — SPDX®“. [Online]. Verfügbar unter: https://www.iso.org/standard/81870.html

[15] CVE Program, „Common Vulnerabilities and Exposures (CVE)“. 2024.

[16] National Institute of Standards and Technology, „National Vulnerability Database (NVD)“. 2024.

[17] A. Anwar, A. Abusnaina, S. Chen, F. Li, und D. Mohaisen, „Cleaning the NVD: Comprehensive Quality Assessment, Improvements, and Analyses“, *IEEE Transactions on Dependable and Secure Computing*, Bd. 19, Nr. 5, S. 3368–3382, 2022, doi: 10.1109/TDSC.2021.3125270.

[18] Z. Shi, N. Matyunin, K. Graffi, und D. Starobinski, „Uncovering CWE-CVE-CPE Relations with Threat Knowledge Graphs“, *ACM Transactions on Privacy and Security*, Bd. 27, Nr. 1, S. 1–26, 2024, doi: 10.1145/3641819.

[19] N. Imtiaz, S. Thorn, und L. Williams, „A Comparative Study of Vulnerability Reporting by Software Composition Analysis Tools“, in *Proceedings of the 15th ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM)*, in ESEM '21. New York, NY, USA: Association for Computing Machinery, 2021, S. 1–11. doi: 10.1145/3475716.3475769.

[20] S. A. Haryono *u. a.*, „Automated identification of libraries from vulnerability data: can we do better?“, in *Proceedings of the 30th IEEE/ACM International Conference on Program Comprehension*, in ICPC '22. Virtual Event: Association for Computing Machinery, 2022, S. 178–189. doi: 10.1145/3524610.3527893.

[21] J. Wunder, A. Corona, A. Hammer, und Z. Benenson, „On NVD Users' Attitudes, Experiences, Hopes and Hurdles“, *ACM Digital Threats: Research and Practice*, Bd. 1, Nr. 1, S. 1–20, 2024, doi: 10.1145/3688806.